

THREAT ADVISORY

VULNERABILITY REPORT

Microsoft addressed ProxyNotShell with November Patch Tuesday

Date of Publication

November 9, 2022

Admiralty Code

A1

TA Number

TA2022248

Summary

First Seen: November 8, 2022

Affected Product: Microsoft Windows and Microsoft Windows Exchange Server

Impact: Bypassing security limitations to attain Remote Code Execution and Privilege Escalation.

CVE

CVE	NAME	PATCH
CVE-2022-41128	Windows Scripting Languages Remote Code Execution Vulnerability	
CVE-2022-41040	Microsoft Exchange Server Elevation of Privilege Vulnerability	
CVE-2022-41082	Microsoft Exchange Server Remote Code Execution Vulnerability	
CVE-2022-41091	Windows Mark of the Web Security Feature Bypass Vulnerability	
CVE-2022-41073	Windows Print Spooler Elevation of Privilege Vulnerability	
CVE-2022-41125	Windows CNG Key Isolation Service Elevation of Privilege Vulnerability	

Vulnerability Details

#1

Microsoft addressed six zero-day vulnerabilities in this patch Tuesday, along with other significant vulnerabilities that could lead to Remote Code Execution, Information Disclosure, and Denial of Service. The actively exploited CVE-2022-41128 RCE bug affects Windows JScript9 Scripting Languages. A remote attacker can deceive the victim into visiting a malicious website, resulting in memory corruption and remote code execution on the compromised system.

#2

Another zero-day vulnerability (CVE-2022-41040) leads to the Elevation of Privilege in the Microsoft Exchange Server due to poor validation of user-supplied input via the Exchange Outlook Web Access (OWA) interface and resulted in the execution of PowerShell in the context of the system. ProxyNotShell flaw tracked CVE-2022-41082 occurs due to incorrect input validation. In an insecure Exchange server, a remote attacker with PowerShell Remoting access can execute the malicious script. These two vulnerabilities were publicly disclosed on 30th September however Microsoft patched it in it's November 2022 Patch Tuesday.

#3

The publicly disclosed CVE-2022-41091 bug is a security feature bypass vulnerability affecting Windows Mark of the Web (MoTW). A hostile actor could create a file that bypasses MoTW, triggering a compromise of integrity and the availability of security features such as Microsoft Office's Protected View.

#4

CVE-2022-41073 and CVE-2022-41125 are zero-day vulnerabilities that exist due to boundary errors within the Windows Print Spooler and the Windows CNG Key Isolation Service, respectively. Successful exploitation of these vulnerabilities could result in SYSTEM privileges.

Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-41128	Windows: 7 - 11 22H2 and Windows Server: 2008 - 2022 20H2	cpe:2.3:o:microsoft:windows:-:*:*:*:*:* cpe:2.3:o:microsoft:windows_server:-:*:*:*:*:*	CWE-119
CVE-2022-41040	Microsoft Exchange Server 2013 Cumulative Update 23, Microsoft Exchange Server 2016 Cumulative Update 22 & 23, and Microsoft Exchange Server 2019 Cumulative Update 11 & 12	cpe:2.3:a:microsoft:microsoft_exchange_server:-:*:*:*:*:*	CWE-918
CVE-2022-41082			CWE-94
CVE-2022-41091	Windows: 10 - 11 22H2 and Windows Server: 2016 - 2022 20H2	cpe:2.3:o:microsoft:windows:-:*:*:*:*:* cpe:2.3:o:microsoft:windows_server:-:*:*:*:*:*	CWE-254
CVE-2022-41073	Windows: 7 - 11 22H2 and Windows Server: 2008 - 2022 20H2	cpe:2.3:o:microsoft:windows:-:*:*:*:*:* cpe:2.3:o:microsoft:windows_server:-:*:*:*:*:*	CWE-119
CVE-2022-41125	Windows: 8.1 - 11 22H2 and Windows Server: 2012 - 2022 20H2	cpe:2.3:o:microsoft:windows:-:*:*:*:*:* cpe:2.3:o:microsoft:windows_server:-:*:*:*:*:*	CWE-119

Recommendations



Security Leaders

Asset and vulnerability management solutions should be implemented to ensure that all internet-accessible devices are secure, patched, updated, hardened, and monitored. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize the vulnerability, identify the impacted assets, and patch them through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Patch Link' on the following pages.

Potential **MITRE ATT&CK** TTPs

<u>TA0001</u> Initial Access	<u>TA0003</u> Persistence	<u>TA0004</u> Privilege Escalation	<u>TA0008</u> Lateral Movement
<u>TA0043</u> Reconnaissance	<u>T1190</u> Exploit Public-Facing Application	<u>T1543</u> Create or Modify System Process	<u>T1547</u> Boot or Logon Autostart Execution
<u>T1574</u> Hijack Execution Flow	<u>T1548</u> Abuse Elevation Control Mechanism	<u>T1546</u> Event Triggered Execution	<u>T1068</u> Exploitation for Privilege Escalation
<u>T1210</u> Exploitation of Remote Services	<u>T1592</u> Gather Victim Host Information		

Patch Link

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41128>

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-41040>

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-41082>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41091>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41073>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41125>

References

<https://msrc.microsoft.com/update-guide/releaseNote/2022-Nov>

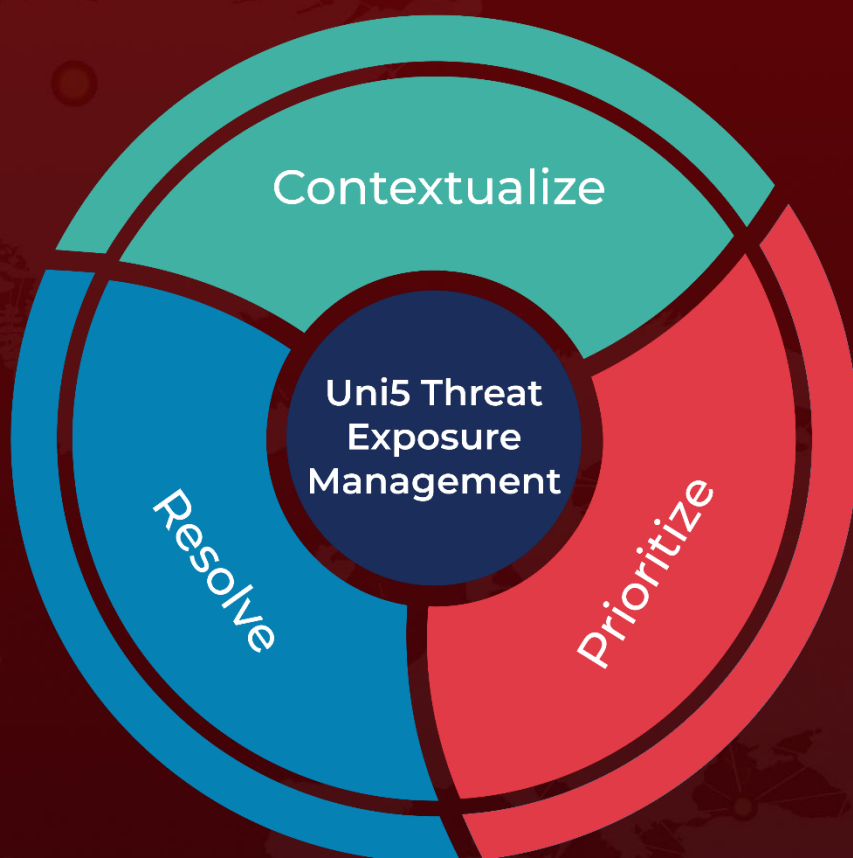
<https://www.tenable.com/blog/microsofts-november-2022-patch-tuesday-addresses-62-cves-cve-2022-41073>

<https://www.bleepingcomputer.com/news/microsoft/microsoft-november-2022-patch-tuesday-fixes-6-exploited-zero-days-68-flaws/>

What Next?

At **HivePro**, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with **Hive Pro Uni5**: Continuous Threat Exposure Management Platform.



REPORT GENERATED ON

November 9, 2022 • 3:00 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com